



NIKE PARTNERS: USING SERVER-TO-SERVER AUTHENTICATION

Table of Contents

[Introduction.....](#) 2

[Key Terms](#) 2

[Prerequisites.....](#) 3

[Get an Access Token](#) 4

[Use an Access Token to Call Nike APIs.....](#) 6

[Document Change Log](#) 7

NIKE PARTNERS: USING SERVER-TO-SERVER AUTHENTICATION

Last Updated: 04/13/2020

The Nike Server-to-Server (S2S) Authentication process allows partners to make authenticated calls to Nike APIs.

Introduction

In this guide, we will step through how to add Nike S2S Authentication to your server app.

What Is S2S Authentication?

S2S Authentication involves obtaining an OAuth 2.0 **access token** from a Nike Okta server so that you can use that token in subsequent calls to Nike APIs to get product data, etc. The process can be summarized as follows:

- Obtain your Nike **Client ID** and **Client Secret** (see [Prerequisites](#))
- Send an API request to the [Nike Okta Server](#) to get an **access token**
- Use the **access token** in the Authorization header to call Nike APIs

Now let's go through some key terms related to S2S Authentication.

Key Terms

Here are some important terms used in this guide.

Term	Definition
Access Token	Token used to make authenticated API calls. Valid for one hour.
Authentication	Confirming the identity of someone or something.
Authorization	Allowing someone or something to perform an action or to access a resource.
Client ID	Unique ID assigned to you by Nike. Along with the Client Secret, use it to get an access token so you can call Nike APIs.

Term	Definition
Client Secret	Unique value assigned to you by Nike. Along with the Client ID, use it to get an access token so you can call Nike APIs.
OAuth 2.0	A standard that apps use to provide client applications with access.
Okta	The authorization server used by Nike to issue OAuth 2.0 access tokens to partners.
Token	A piece of data that has no meaning or use on its own, but combined with the correct tokenization system, allows a server to authenticate an incoming request.

Prerequisites

You need to complete the steps below before you can add S2S Authentication to your server app.

1. Pair Up With a Nike Account Manager (AM) And Technical Point Of Contact (TPC)

Your Nike Business Lead (NBL) will put you in touch with these two points of contact. These contacts help make your integration go smoothly by communicating with various internal Nike teams for you. Your AM handles privacy and legal details. Your TPC handles the technical details of your project.

2. Gather Your Project Requirements

This is the step where you provide Nike with information about your project and your technical needs.

Your **AM** needs to know:

Project Information

- **Partner name:** What is the name of your company?
- **Project name:** What are you calling your project?
- **Project contacts:** Who are the business and technical contacts for your project?
- **Project goals:** What are the expected outcomes of your project? How does this project benefit your company? Providing URLs to your public-facing project documentation is helpful, too.
- **Project timeline:** What are the dates of your project milestones e.g. integration testing, end-to-end testing, production go-live?
- **Contract status:** Where in the contract life cycle is your project? Has it been drafted by Nike, reviewed, and signed by both parties?

Your **TPC** needs to know:

Technical Information

- **List of Nike APIs:** Decide what Nike APIs you need to call to meet your project goals. Talk with your TPC to learn more about Nike APIs and how they can fulfill your business objectives.
- **Nike API usage:** What are the consumer interactions with Nike APIs? Where and how will Nike APIs be accessed in your project?
- **Data:** What partner data will be shared with Nike? What Nike data will be shared with you?
- **Location of your test and production environment:** We'll need to know your hosting platform, physical location, and consumer-facing URL. We will also need your test and production URLs to add to our list of approved redirects. Nike only redirects to URLs on the whitelist.
- **Site traffic requirements:** How many visitors do you expect over what time period? How many simultaneous visitors do you expect at peak times?
- **Links to your Terms of Service and Privacy Policy Pages:** Nike includes these links as part of your partner configuration. These links display on your customized Connect Your Nike Account page where the consumer gives your app/experience permission to connect to their Nike account. Note that your pages must be static and available in every language you support as Nike cannot pass locale parameters.

3. Get Legal And Privacy Approval

Your NBL will make sure that your project contract is ready to go and that all of the data exchanged between your app and Nike is handled securely. This process generally takes 1-5 business days.

4. Get Your OAuth Credentials

Once the above prerequisites are complete, your TPC will give you your OAuth credentials (**Client ID** and **Client Secret**) so that you can take the next steps towards calling Nike APIs.

TIP: Do not share your Client Secret and make sure you store it securely.

Get an Access Token

✓ Get your access token so that you can make API calls

After completing all the action items in the [Prerequisites](#) section, you are ready to add Nike S2S Authentication to your server app.

Step 1: Send a Request to the Nike Okta Server

In this step, you will get your access token by calling the appropriate Nike Okta endpoint with your **Client ID** and **Client Secret**.

NOTE: Nike uses the OAuth 2.0 Client Credentials flow for S2S Authentication.

Required Header Fields:

Content-Type: application/x-www-form-urlencoded

POST Request URI

https://nike.okta.com/oauth/aus27z7p76as9Dz0H1t7/v1/token

Required POST request body fields:

Field Name	Description
grant_type	Type of requested access, always client_credentials
client_id	Unique Client ID assigned to your project as an outcome of the Prerequisites phase
client_secret	Unique Client Secret generated as an outcome of the Prerequisites phase

Example request body:

```
grant_type=client_credentials
client_id=company.digital.app
client_secret=yno-
T08MctEfC4-0a6ufazFkxwZPYoWBODN9cJYhUieDCv9vLR3dsQ2WgnL69Ejx
```

Example 200 (success) response, which includes your access_token, expires_in (the number of seconds until the access token expires), and the token_type, always "Bearer".

```
{
  "access_token": "eyJhbG[... ]1LQ",
  "token_type": "Bearer",
  "expires_in": 3600,
  "scope": "customScope"
}
```

TIP: By default, access tokens expire after 1 hour (3600 seconds).

Example 400 Bad Request response indicating an invalid `client_id`:

```
{
  "errorCode": "invalid_client",
  "errorSummary": "Invalid value for 'client_id' parameter.",
  "errorLink": "invalid_client",
  "errorId": "oaeh2ort7OZRw28rexq73ebhA",
  "errorCauses": [ ]
}
```

Use an Access Token to Call Nike APIs

Now that you have a valid access token, you are ready to make authenticated calls to Nike APIs.

Step 1: Reformat the Access Token

Nike APIs require the access token in a particular format within the `Authorization` request header. Here are the steps to accomplish this:

- Concatenate `Bearer` (note the space at the end) and your access token into a single string, for example:

NIKE PARTNERS: USING SERVER-TO-SERVER AUTHENTICATION

Bearer

eyJhbGciOiJSUzI1NiIsImtpZCI6IjYzMjdkgOGU4LWNlNmMtNGI0MC1iYTdmLTRmYmI0OTM4Zjc4NnNpZyJ9.eyJ0cnVzdCI6MTAwLkCjPjYXQiOiJlODM4MTA5NjQsImV4cCI6MTU4MzgxNDU2NiwiaXNzIjoib2F1dGgyYWNjIiwianRpIjoizDNjMjQyMTctZmRkMC00MjY4LWI4NzEtODNmN2E4NDNjNTZhIiwibGF0IjoxNTgzODEwOTY0LCJhdWQiOiJjb20ubmlrZS5kaWdpdGFsIiwic3ViIjoiiY29tLm5pa2UuY29tbWVyY2UubmlrZWVvdGNvbS53ZWIIiLCJzYnQiOiJuaWt1OmFwcCIsc3lnInNjcCI6WyJuaWt1LmRpZ210YWwiXSwicHJuaWt1ODczMjE0ODI3OCIsInBydCI6Im5pa2U6cGx1cyJ9.G_Ggf_TzI3AiUO-
1TiL4JjOAbDH_4Ps5sSMJH0mrK5k0tPYdXJrwaJX65HYNuhRnsJk58KuNGk-
KxeXV1nXidnY2qCIn6lLhatS0P0TMrZk2BI0K7iWZeJEmzzMNRHmgYfLvJy9nM9lsGcdJLJ3z
qlu0t38bNtvdOK8CKL9ui8_ltbl6BrROKxFvOPggjg04SL-3TJxqREjxTTtrKnK2DJOIEAs_DA
LLknvWKQByfGx5kk-
HiQN5fLRecRpyEhhBJ1x0AaepKBe9zDYGWZ8ttGq10M55FZ58_bCgIdu-
Hf4JwFyjel9ipEdnDLPfb2v63Nitbami-HVpcEoiivsre3g

- Include the concatenated value in the `Authorization` header of your API request.

Document Change Log

Summary	Date
Initial publish	04/13/2020